

Detecting Post-Compromise Lateral Movement Using Authentication Logs

A Graph-Based Anomaly Detection Framework - Independent Synthetic Benchmark

Daniel Peng

New York University, New York, NY, USA

ABSTRACT

Perimeter defenses focus on preventing initial access, but once valid credentials are compromised, lateral movement toward high-value systems can blend with legitimate activity. This poster independently evaluates whether graph-assisted authentication analysis improves detection over a simple novelty-rule baseline. The public synthetic dataset contains 180,000 events across 30 days, 498 active users, 150 destination hosts, and 16,391 labeled attack chains aligned with MITRE ATT&CK T1078 and T1021. A chronological baseline, fit, and held-out test design is used. Under the same 32,013-alert review budget, the graph-based method achieved 0.823 precision, 0.623 recall, and 0.119 FPR, compared with 0.687, 0.520, and 0.210 for the baseline. Because the data and labels are synthetic and attack-enriched, the results demonstrate feasibility rather than validated production performance.

180K

events

498

active users

150

destination hosts

16,391

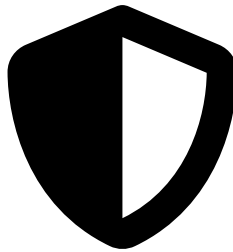
attack chains

I. INTRODUCTION

Enterprise security often prioritizes initial compromise through firewalls, multifactor authentication, and intrusion prevention. After an attacker obtains valid credentials, subsequent activity can resemble normal employee or administrator behavior.

Lateral movement is the bridge from one compromised endpoint to wider enterprise access. Static rules can over-alert on benign novelty or miss pivots that reuse familiar systems in an unusual order.

This study asks a narrow question: on a controlled synthetic benchmark, does relational context improve separation between benign and malicious authentication events when both detectors receive the same alert budget?



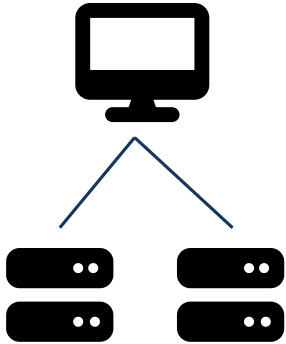
Research question: does relational context improve detection under the same alert budget?

II. PROBLEM DOMAIN



Credential-based attacks are difficult to detect after compromise because stolen credentials can produce technically valid logins. Attackers can pivot through ordinary workstations and servers while appearing similar to legitimate administrative activity.

Entry-point controls such as IP blocking and account lockouts do not directly model the sequence or relational context of internal movement. This can create high false-positive volume while still missing low-and-slow pivots.



The central challenge is balancing detection effectiveness with analyst usability. Event-level novelty can be benign, while a familiar host may become suspicious when it appears in an unusual path, sequence, or burst of activity. This motivates models that consider who normally accesses which systems and how those relationships change over time.

Techniques represented in the dataset

T1078 Valid Accounts
Use of stolen or otherwise compromised credentials.

T1021 Remote Services
Lateral movement through internal remote-access services.

High-value target
A simulated domain controller named DC-01.

III. METHODOLOGY

A. Detection Pipeline

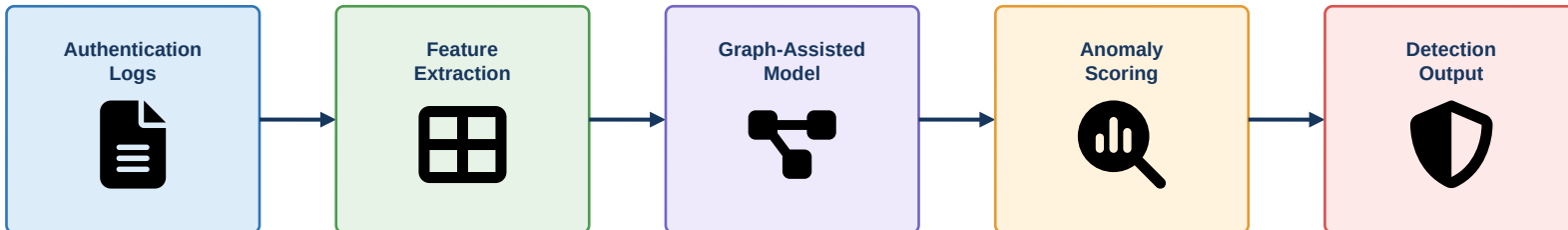


Fig. 1. Analysis pipeline from authentication events to alert output.

B. Detection Approaches

1) Rule-Based Baseline

- Flags a first-time destination host for a user
- Flags a previously unseen source subnet
- Updates observed history in chronological order
- Simple benchmark, not a modern commercial UEBA system

2) Graph-Based Method

- N: new user-to-destination relationship
- R: destination is closer to DC-01 than the user's historical footprint
- D: positive deviation in daily distinct-user activity at the destination
- Logistic regression fitted on the chronological fit period

$$\text{logit } P(\text{malicious}) = \text{beta0} + \text{beta1 } N + \text{beta2 } R + \text{beta3 } D$$

Coefficients are learned from labeled fit-period events. Final test alerts are ranked without using test labels.

C. Relational Representation

Historical user-host relationships define normal access. Hosts co-accessed by users form a graph used to estimate paths toward DC-01.

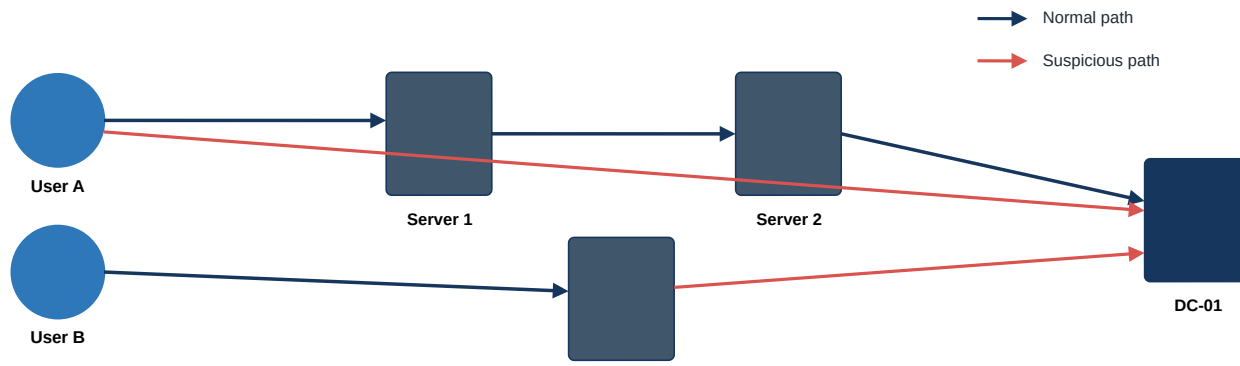


Fig. 2. Example of ordinary and suspicious access relationships.

IV. EVALUATION SETUP

Observed dataset

Events	180,000 across 30 days
Users	498 active users
Hosts	150 destination hosts, including DC-01
Chains	16,391 labeled T1078/T1021 chains
Labels	115,140 benign and 64,860 malicious events

Chronological design

- Baseline: 42,000 benign events, days 1-7
- Fit: 48,000 events, days 8-15
- Held-out test: 90,000 events, days 16-30
- Equal test alert budget: 32,013 alerts per method

Metrics

	Precision	Fraction of alerts that are malicious
	Recall	Fraction of malicious events detected
	FPR	FP divided by all benign events

Attack-enriched benchmark: 36% malicious overall and 47% malicious in the test period.

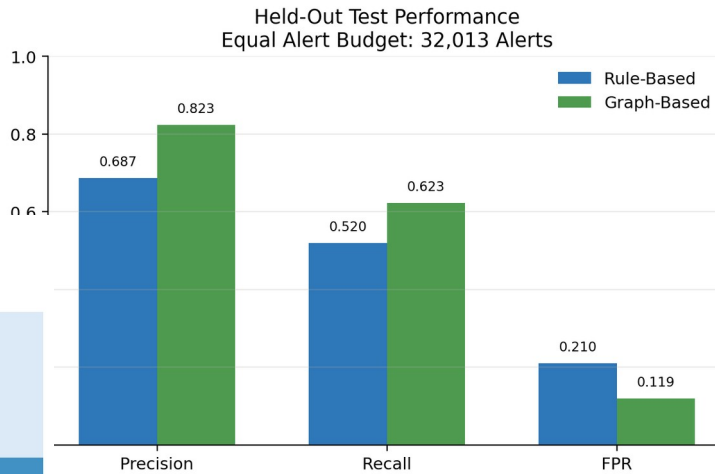
V. RESULTS

Under the same 32,013-alert review budget, the graph-based method improved every event-level metric on the held-out test set.

Method	Precision	Recall	FPR
Rule-Based	0.687	0.520	0.210
Graph-Based	0.823	0.623	0.119

Held-Out Test Confusion Matrices

Rule-Based		Graph-Based	
Actual Benign	37,683	10,017	5,677
Actual Malicious	20,304	21,996	26,336
	Pred. Benign	Pred. Benign	Pred. Malicious



Observed interpretation

- Precision increased by 13.6 percentage points
- Recall increased by 10.3 percentage points
- FPR decreased by 9.1 percentage points
- Attack-chain detection: 97.4% graph vs 94.1% baseline
- Tradeoff: DC-target recall was 65.6% graph vs 100% baseline

Fig. 3. Point estimates from one held-out test set. No target metrics or repeated-run averages are used.

VI. CONCLUSION

On the held-out test period, graph-assisted scoring improved precision and recall while reducing the false-positive rate under the same alert volume. It also detected a larger fraction of attack chains. However, the simple rule baseline captured more malicious DC-01 target events, showing that aggregate gains can hide target-specific tradeoffs. The study supports graph context as a useful feasibility direction, not as evidence of production readiness.

+13.6 pts

Precision

+10.3 pts

Recall

-9.1 pts

FPR

VII. FUTURE WORK



Validate on real datasets such as LANL and CERT



Test realistic low-prevalence and noisy-label settings



Compare with peer-group, UEBA, and stronger temporal baselines



Add endpoint and network telemetry; evaluate temporal GNNs



Measure scalability and streaming latency in larger environments

REFERENCES



- [1] C. Herley and D. Florencio, "Protecting Financial Institutions from Brute-Force Attacks," IFIP SEC, 2008.
- [2] R. Sommer and V. Paxson, "Outside the Closed World: On Using Machine Learning for Network Intrusion Detection," IEEE S&P, 2010.
- [3] V. Chandola et al., "Anomaly Detection: A Survey," ACM Computing Surveys, 41(3), 2009.
- [4] MITRE ATT&CK, T1078 and T1021.
- [5] A. D. Kent, "Comprehensive, Multi-Source Cyber-Security Events," LANL, 2015.
- [6] D. Peng, "Synthetic Enterprise Authentication Logs," Kaggle, 2026.